



ศูนย์เทคโนโลยีอิเล็กทรอนิกส์ และคอมพิวเตอร์แห่งชาติ (NECTEC)

นายธนภูมิ ศรีกาญจน์

ผู้ฝึกงานด้านการวิเคราะห์ความมั่นคงปลอดภัยไซเบอร์

Cybersecurity Analysis Trainee

รหัสนักศึกษา 1650706284 • สาขาวิชาวิทยาการคอมพิวเตอร์

คณะ เทคโนโลยีสารสนเทศและนวัตกรรม มหาวิทยาลัยกรุงเทพ

ภาคการศึกษา 3 / 2568

อาจารย์ที่ปรึกษา



หน้าอาคาร NECTEC อุทยานวิทยาศาสตร์ประเทศไทย พร้อมบัตรผู้ฝึกงาน

NECTEC ศูนย์วิจัยแห่งชาติด้านอิเล็กทรอนิกส์และคอมพิวเตอร์

ชื่อและที่ตั้ง

ศูนย์เทคโนโลยีอิเล็กทรอนิกส์และคอมพิวเตอร์แห่งชาติ เลขที่ 112 อุทยาน
วิทยาศาสตร์ประเทศไทย ถนนพหลโยธิน อำเภอคลองหลวง จังหวัดปทุมธานี

ลักษณะการประกอบการ

วิจัยและพัฒนา · ถ่ายทอดเทคโนโลยีสู่อุตสาหกรรม · พัฒนาบุคลากร · สร้าง
โครงสร้างพื้นฐานด้านวิทยาศาสตร์และเทคโนโลยี

รูปแบบการบริหาร

ศูนย์แห่งชาติเฉพาะทางภายใต้ สวทช. แบ่งงานเป็นทีมวิจัย โดยหัวหน้าทีมเป็นผู้
กำหนดทิศทางและกำกับงาน

2529

ก่อตั้ง 16 กันยายน

2534

เข้าสังกัด สวทช.

40 ปี

ครบรอบในปี 2569



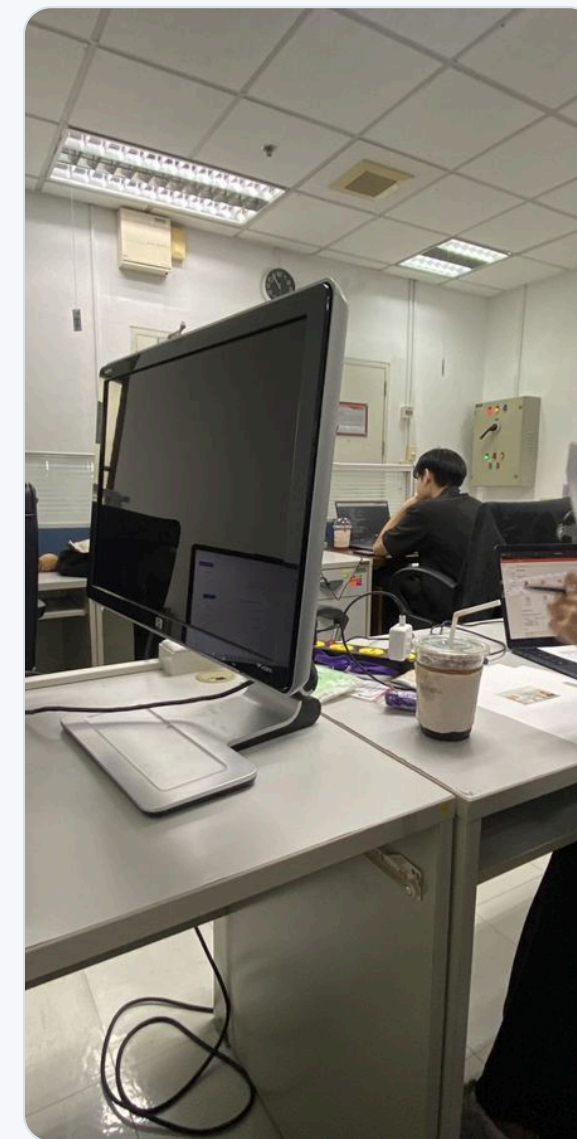
ป้ายและอาคาร NECTEC สถานที่ปฏิบัติงาน

ผู้ฝึกงานในทีมวิจัยความมั่นคงปลอดภัยสารสนเทศ

ตำแหน่ง	Cybersecurity Analysis Trainee
ลักษณะงาน	ตรวจทานและทดสอบความปลอดภัยของระบบที่ใช้งานจริง ร่วมทำงานวิจัยเชิงทดลอง และสนับสนุนห้องทดลองตรวจ จับภัยคุกคาม
สังกัด	ทีมวิจัยความมั่นคงปลอดภัยสารสนเทศ NECTEC
ผู้ควบคุมงาน	คุณเอกฉัตร รัตนเลิศนุสรณ์ หัวหน้าทีมวิจัยความมั่นคง ปลอดภัยสารสนเทศ
ระยะเวลา	22 มิถุนายน – 9 ตุลาคม 2569 (16 สัปดาห์)
เวลาทำงาน	จันทร์–ศุกร์ 08:30–17:00 น. เข้าออฟฟิศสลับกับทำงาน จากบ้าน



ห้องทำงานของทีมวิจัย



โต๊ะที่ใช้พัฒนาและทดสอบระบบ

งาน 3 ชิ้น จุดร่วมคือความปลอดภัยของระบบที่ใช้งานจริง

งานที่ 1 • ป้องกันระบบ

AtTime ระบบลงเวลาด้วยใบหน้า

งานหลัก ตรวจสอบโค้ด ทดสอบความปลอดภัยในมุมมองผู้โจมตี และนำระบบขึ้นเซิร์ฟเวอร์จริง

8 Pull Request ขึ้นเซิร์ฟเวอร์จริง ไม่มีข้อสงสัย

งานที่ 2 • วัดความทนทาน

บทความวิจัย AINTEC 2026

ทีม 3 คน ร่วมคิดแนวทางแก้ปัญหา และตรวจสอบความถูกต้องของตัวเลขและข้อสรุป

11 ชุดการทดลอง รวม 6,520 trials

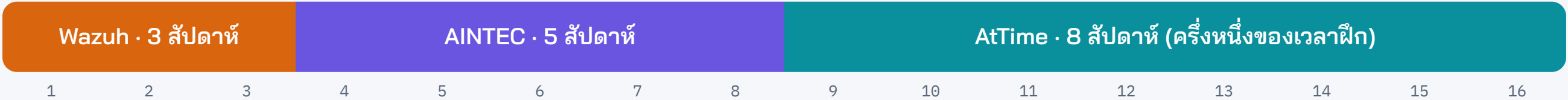
งานที่ 3 • ตรวจสอบการโจมตี

ห้องทดลอง DVWA-Wazuh

ผมติดตั้งและตั้งค่า Ollama เป็นบริการแบบจำลองภาษาภายในให้ทีมเรียกใช้

ทีมทดสอบแล้ว 8 จาก 15 หัวข้อการโจมตี

ช่วงเวลา 16 สัปดาห์ (22 มิ.ย. – 9 ต.ค. 2569)



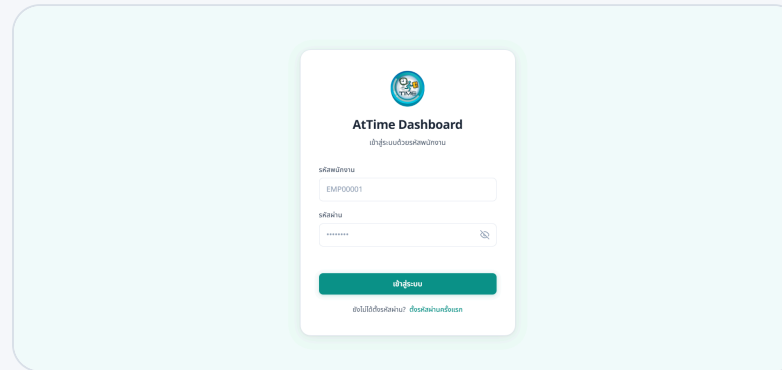
AtTime ลงเวลาด้วยใบหน้าผ่าน LINE ผู้ดูแลผลใน Dashboard

LINE → สแกนหน้า + GPS → backend →
Dashboard

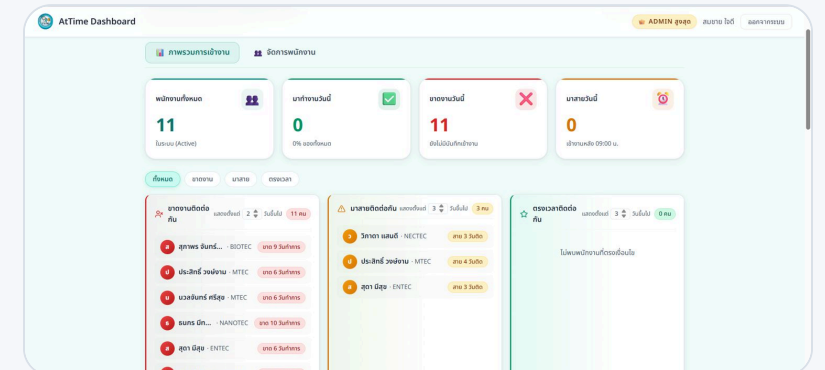
บทบาทของผม ตรวจสอบโค้ดที่ละไฟล์ก่อนรวมเข้าระบบ ทดสอบความปลอดภัยในมุมผู้โจมตี และนำขึ้นเซิร์ฟเวอร์จริง

- สิทธิผู้ดูแล 2 ระดับ: เห็นทุกหน่วยงาน หรือเฉพาะหน่วยงานของตน
- nginx → frontend 4 ส่วน → FastAPI → PostgreSQL 16 รันด้วย Docker Compose 7 container
- ใช้ผู้ช่วยเขียนโค้ด AI ร่างโค้ด และตรวจ diff ทุกไฟล์ก่อน merge

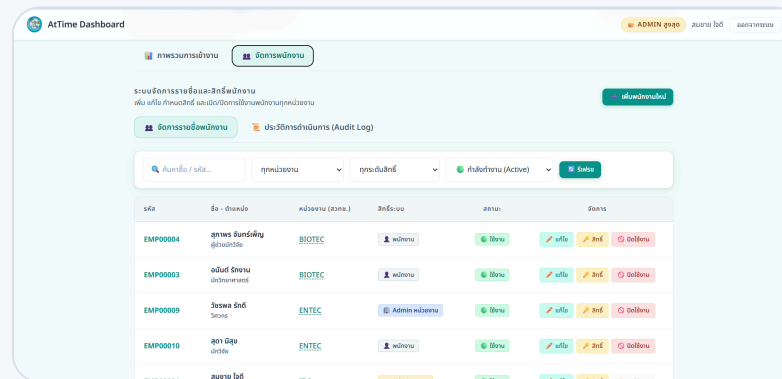
ระบบยังไม่ส่งมอบ ผู้ใช้ทั้งหมดเป็นทีมงาน ข้อมูลในภาพเป็นข้อมูลทดสอบ



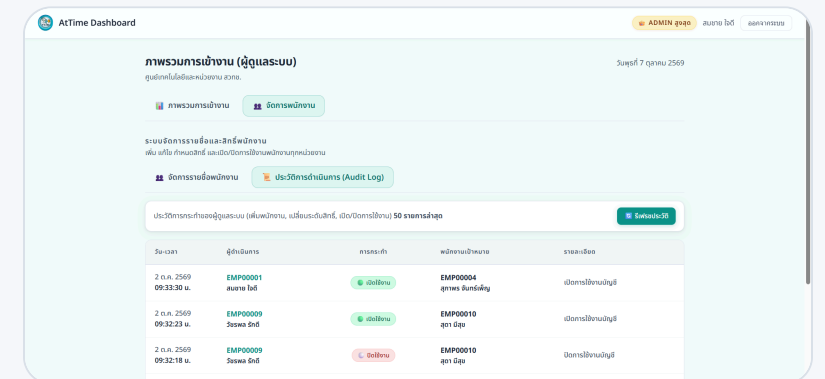
1 เข้าสู่ระบบ ยืนยันตัวตนด้วยรหัสพนักงาน ตั้งรหัสครั้งแรกด้วย OTP ทาง LINE



2 ภาพรวมการทำงาน วันนี้ใครมา สาย ชขาด และใครควรติดตาม



3 จัดการพนักงาน เพิ่ม แก้ไข กำหนดสิทธิ์ เปิดหรือปิดบัญชี



4 Audit Log บันทึกว่าผู้ดูแลคนใดทำอะไร กับใคร เมื่อใด

คิดแบบผู้โจมตี แล้วปิดที่ละความเสี่ยง

ความเสี่ยง	หมายความว่า	วิธีป้องกัน
IDOR ที่หน้าประวัติ	รู้รหัสของคนอื่นแล้วเปิดดูประวัติได้	backend ตรวจสอบ LIFF token กับ LINE ว่าเป็นเจ้าของบัญชีจริง คนละคนตอบ 403
บัญชีที่ปิดแล้วยังใช้ได้	บัญชีที่ควรระงับยังสแกนและดูประวัติได้	ตอบ 403 ทุกจุดที่เกี่ยวข้อง กั้นการลงทะเบียนซ้ำ
รูปใบหน้ารั่วไหล	ข้อมูลชีวมิติ เปลี่ยนไม่ได้เหมือนรหัสผ่าน	ต้องล็อกอิน จำกัดตามหน่วยงาน กั้น path traversal 2 ชั้น
ไม่มีหลักฐานย้อนหลัง	ผู้ดูแลแก้ไขแล้วตามรอยไม่ได้	Audit Log บันทึกผู้ทำ การกระทำ เป้าหมาย เวลา

ยังเปิดอยู่ endpoint สแกนและลงทะเบียนยังเชื่อมรหัสจากฝั่ง client • LIFF ระยะสองยังไม่เปิด • รหัสผ่านเริ่มต้นควรถูกบังคับเปลี่ยน

ทุกรอบ deploy สำรองก่อน ถอยกลับได้

A เตรียมค่า → B สำรอง DB + รูป ติดแท็กจุดถอยกลับ →

C สลับเฉพาะส่วนที่เปลี่ยน

8

Pull Request ที่ merge และ deploy

5

ปัญหาที่ปิดในช่วง 2–6 ต.ค.

9/10

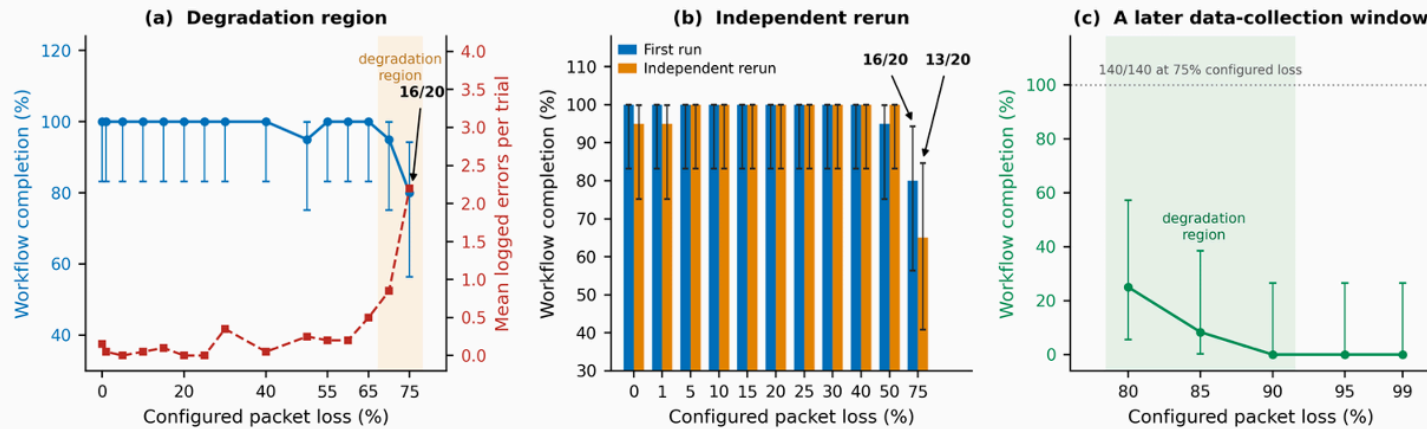
รายการทดสอบบนเซิร์ฟเวอร์ที่ผ่าน

275

รูปคงที่ก่อนและหลัง ไม่มีข้อมูลหาย

ถ้าเครือข่ายไปยังโมเดลมีปัญหา งานของ AI agent ยังเสร็จไหม

Planner → Worker → Reviewer ⇒ **Linux tc / netem** ⇒ Ollama model server



กราฟจากบทความ: แกนนอนคือ packet loss ที่ตั้งไว้ แกนตั้งคืออัตราที่ workflow ทำงานสำเร็จ (a) ช่วงที่เริ่มลดลง (b) การทดลองซ้ำ (c) ช่วงเก็บข้อมูลถัดมา

- packet loss เริ่มกระทบที่ **70–75%** (สำเร็จ 19/20 และ 16/20)
- delay ถึง 3,000 ms, jitter และ bandwidth ต่ำ ไม่พบการลดลงที่เทียบได้
- ปรับ timeout ตามสภาพเครือข่าย ได้ 20/20 เทียบ 14/20 แต่ยังไม่สรุปเป็นเหตุและผลไม่ได้

6,520

trials รวม

11

ชุดการทดลอง

ส่วนของผม: ตรวจสอบ 3 วิธี

- คำนวณตัวเลขและค่า p ช้ำ ได้ $p = 0.0202$ ตรงกับบทความ
- ตรวจสอบข้อสรุปไม่เกินหลักฐาน แยกผลเชิงสำรวจออกจากผลหลัก
- ร่วมไล่หาสาเหตุของผลที่ไม่ตรงคาด จนพบว่าค่า timeout ไม่ถูกส่งถึงตัวเรียกโมเดล

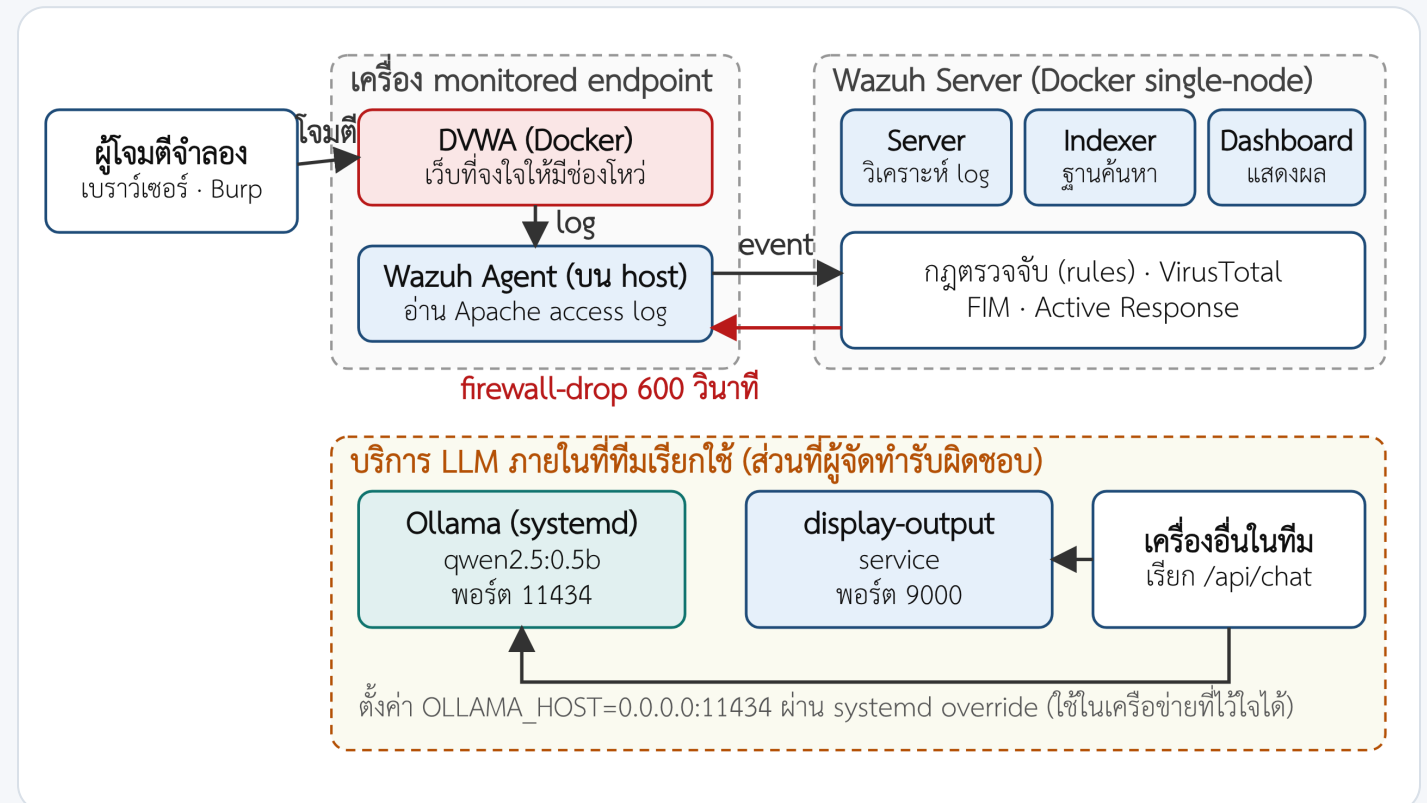
มุมมองความปลอดภัย: เป็นเรื่อง availability ของบริการ AI หนึ่งในสามหลัก CIA

โจมตีเว็บที่ตั้งใจให้มีช่องโหว่ แล้วดูว่าตรวจจับได้ไหม

ส่วนของผม ติดตั้งและตั้งค่า Ollama เป็นบริการแบบจำลองภาษาภายใน ให้เครื่องอื่นในทีมเรียกใช้ได้

1. ติดตั้ง Ollama และเปิดเป็น service
2. ดึงโมเดล qwen2.5:0.5b
3. ตั้ง OLLAMA_HOST ผ่าน systemd override
4. ตรวจสอบพอร์ต 11434 และทดสอบ API จากเครื่องอื่น

บทเรียน Ollama ไม่มีการยืนยันตัวตนในตัว จึงเปิดเฉพาะในเครือข่ายที่ไว้ใจได้



สถาปัตยกรรมห้องทดลอง: ผู้โจมตีจำลอง → DVWA → Wazuh Agent → Wazuh Server ส่วนล่างคือบริการ LLM ที่ผมรับผิดชอบ

8/15

หัวข้อการโจมตีที่ทีมทดสอบแล้ว
(ระดับ Low)

600 วิ

Active Response บล็อก IP ผู้โจมตี
อัตโนมัติ

เครื่องมือที่ใช้ แยกตามงาน

งานที่ 1 · AtTime

พัฒนา ทดสอบ และ deploy ระบบจริง

Python 3.12

FastAPI

PostgreSQL 16

nginx

Docker Compose

JWT

LINE LIFF

Git / GitHub

Pull Request

ผู้ช่วยเขียนโค้ด AI

งานที่ 2 · AINTEC

ทดลองและวิเคราะห์ผลเชิงสถิติ

AutoGen

Ollama

qwen3:8b

llama3.1:8b

Docker

Linux tc / netem

Python

Fisher's exact test

งานที่ 3 · DVWA-Wazuh

ตรวจจับการโจมตีและบริการ LLM

Wazuh

DVWA

Docker

Ollama

qwen2.5:0.5b

systemd

curl

Burp Suite

เครื่องมือที่ไม่เคยใช้มาก่อนฝึกงาน ได้แก่ FastAPI, Docker Compose, LINE LIFF, tc/netem และ Wazuh

ผลงานจาก 3 งาน เป็นตัวเลขที่ตรวจสอบได้

งานที่ 1 · AtTime

8

Pull Request merge และ deploy

5

ปัญหาที่ปิดแล้ว

9/10

รายการทดสอบบนเซิร์ฟเวอร์ที่ผ่าน

0

ข้อมูลสูญหายจากการ deploy

ปิดช่องโหว่ IDOR บล็อกบัญชีที่ปิดใช้งาน ป้องกันรูปใบหน้า และเพิ่ม Audit Log

งานที่ 2 · AINTEC

11

ชุดการทดลอง

6,520

trials

ตัวเลขและค่า p ที่คำนวณซ้ำตรงกับบทความ และระบุข้อจำกัดของการทดลองอย่างตรงไปตรงมา

งานที่ 3 · Wazuh

1

บริการ LLM ภายในทีม

8/15

หัวข้อที่ทีมทดสอบแล้ว

เครื่องมือในทีมเรียกใช้ Ollama ผ่าน API ได้

สิ่งที่ควรบอกควบคู่: ระบบ AtTime ยังไม่ส่งมอบ มี 1 รายการที่ยังไม่ได้ทดสอบบนเซิร์ฟเวอร์ และยังมีความเสี่ยงที่ต้องปิดในรอบถัดไป

ข้อดีของสหกิจศึกษา และการวิเคราะห์ตนเอง

S

จุดแข็ง

- ได้ลงมือกับงานจริง 3 แบบ: ระบบจริง งานวิจัย ห้องทดลอง
- มีวินัยก่อนแต่ละระบบจริง: ตรวจ diff สำรองข้อมูล มีจุดถอยกลับ
- มองงานแบบผู้โจมตี จึงพบจุดอ่อนอย่าง IDOR ได้

W

จุดอ่อน

- ต้องเรียนเครื่องมือใหม่หลายตัวใน 16 สัปดาห์
- ประสบการณ์ดูและระบบ production ยังน้อย
- กักขะเขียน backend ด้วยตนเองยังต้องพัฒนาต่อ

O

โอกาส

- ได้เรียนรู้จากนักวิจัยและพี่เลี้ยงที่มีประสบการณ์
- มีผลงานที่ตรวจสอบได้เป็นพอร์ตโฟลิโอ (PR, deploy, บทความ)
- ต่อยอดสู่สาย Security Analyst หรือ DevSecOps

T

อุปสรรค

- ข้อมูลและโค้ดบางส่วนเปิดเผยได้จำกัด
- ภัยคุกคามและเทคโนโลยี AI เปลี่ยนเร็ว ต้องเรียนรู้ต่อเนื่อง
- ถ้า AtTime มีผู้ใช้จริงเพิ่ม ความเสี่ยงที่เปิดอยู่จะรุนแรงขึ้น

ข้อดีที่ได้ ใช้ความรู้ฐานข้อมูล เครือข่าย และความปลอดภัยกับระบบจริง และทำงานเป็นทีมผ่าน Git และ Pull Request

ข้อเสนอแนะ ควรมีสภาพแวดล้อมทดสอบแยกจากเซิร์ฟเวอร์จริง และรุ่นน้องควรเตรียมพื้นฐาน Linux, Git, Docker ก่อนมาฝึก

สองกิจกรรมที่ทำให้เห็นภาพใหญ่ของ NECTEC

9 ก.ค. 2569 สัมมนาความมั่นคงปลอดภัยทางไซเบอร์

ฟังเวทีเสวนาจากวิทยากรหลายท่าน ได้ข้อคิดว่าความปลอดภัยเป็นเรื่องของคน และกระบวนการ ไม่ใช่เครื่องมืออย่างเดียว



ห้องสัมมนาและเวทีเสวนา



วิทยากรบนเวที

15 ก.ย. 2569 งานครบรอบ 40 ปี NECTEC “Legacy & Beyond”

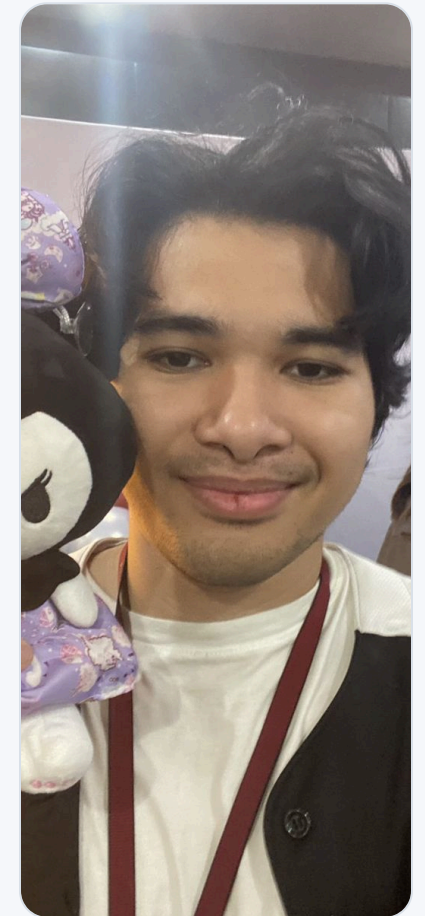
เห็นงานวิจัยหลายสาขา ได้พบบุคลากรต่างทีม และเห็นวัฒนธรรมองค์กรที่ใส่ใจคน มีเกมคืบตุ๊กตา คลายเครียดและอาหารแจกตลอดงาน



ในโรงจัดงาน



ชูนวัตกรรมสาร



ร่วมกิจกรรมในงาน

ขอบคุณครับ

ขอบคุณคุณเอกฉันทน์ รัตนเลิศนุสรณ์ ทีมวิจัยความมั่นคงปลอดภัย
สารสนเทศ NECTEC และอาจารย์ที่ปรึกษา

ยินดีตอบคำถามครับ

ผู้นำเสนอ นายธนภูมิ ศรีกาญจน์ • 1650706284

อีเมล tanapoom.srik@bumail.net



กับเพื่อนร่วมทีมงานที่ NECTEC